

# Audit Internal SMKI ISO/IEC 27001:2022

Sistem Manajemen Keamanan Informasi dalam Operasional  
E-Commerce Pemesanan Tiket Online - PT Jelajah Dunia.

## TEMUAN UTAMA AUDIT

Teridentifikasi **4 Major Non-Conformity** yang seluruhnya memerlukan Corrective Action Plan sebelum External Surveillance Audit 1 - Juni 2026.



**Syahril Arfian Almazril**  
Ketua Tim Audit Internal · Lead Auditor

## INFORMASI AUDIT

### JENIS AUDIT

Audit Internal - Pihak Pertama

### PERIODE AUDIT

6 - 24 Januari 2026

### STANDAR ACUAN

ISO/IEC 27001:2022 · ISO 19011:2018

### NO. LAPORAN

LAI/ISMS/001/I/2026

### LOKASI

Gedung 456, Pasar Minggu, Jakarta  
Selatan

## TARGET KESIAPAN

**Juni 2026**

External Audit ISO 27001

Surveillance 1

# Mengapa Audit Ini Dijalankan & Apa yang Dinilai

## — KONTEKS & SASARAN AUDIT

PT Jelajah Dunia memegang sertifikasi **ISO/IEC 27001:2022** untuk operasional e-commerce pemesanan tiket online. Audit internal pihak pertama ini menilai efektivitas SMKI menjelang **Surveillance Audit Juni 2026** , di tengah relokasi kantor Bandung ke Jakarta (Jun - Agt 2025) yang mengubah profil risiko.

- 01

**Menilai Efektivitas SMKI**  
Mengevaluasi efektivitas implementasi SMKI di seluruh lingkup operasional perusahaan.
- 02

**Memastikan Kepatuhan**  
Menguji kepatuhan klausul mandatori (Clause 4-10) & kontrol Annex A serta kebijakan internal.
- 03

**Mengidentifikasi Gap**  
Menemukan gap & area perbaikan sebelum External Surveillance 1 pada Juni 2026.

## — IN SCOPE - 4 AREA FOKUS

|                                                                                                                                                                                                                                                                   |                                                                                                                             |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|
| <div><b>Human Capital</b><br/>Background Screening kandidat &amp; karyawan baru.</div> <div>A.6.1A.6.2PNP/HC/012</div>                                                                                                                                            | <div><b>IT GRC - Risk Mgmt</b><br/>Penilaian &amp; pemutakhiran risiko keamanan informasi.</div> <div>Clause 6.1.28.2</div> |
| <div><b>IT GRC - Access Control</b><br/>Pengendalian &amp; tinjauan hak akses kuartalan.</div> <div>A.5.15A.5.18PNP/IT/002</div>                                                                                                                                  | <div><b>Engineering</b><br/>Change Management &amp; Network Security production.</div> <div>A.8.32A.8.20PNP/IT/004</div>    |
| <div><div>OUT OF SCOPE</div><div>Clause 4-10 di luar 6.1.2 &amp; 8.2</div><div>Annex A domain lain</div><div>Finance &amp; non-IT</div><div>Verifikasi populasi penuh</div></div>                                                                                 |                                                                                                                             |
| <div><b>MANDAT AUDIT</b><br/>Mengidentifikasi gap kepatuhan lebih awal agar dapat ditindaklanjuti melalui <b>Corrective Action Plan</b> sebelum penilaian eksternal - sekaligus menjaga kepercayaan pelanggan atas keamanan data transaksi pemesanan tiket.</div> |                                                                                                                             |

# Dasar Penilaian, Pelaksana & Tahapan Audit

## KRITERIA & STANDAR ACUAN

|                                                                                   |                                                                                                                                                         |
|-----------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <b>ISO/IEC 27001:2022</b><br>Klausul mandatori (Clause 4-10) & kontrol Annex A relevan.<br><div>6.1.2 / 8.2A.5.15 / 5.18A.6.1A.8.32 / 8.20</div>        |
|  | <b>ISO 19011:2018</b><br>Panduan audit sistem manajemen - berbasis risiko.                                                                              |
|  | <b>Kebijakan Internal &amp; Regulasi</b><br>Prosedur perusahaan & perlindungan data pribadi.<br><div>PNP/HC/012PNP/IT/002PNP/IT/004UU PDP 27/2022</div> |

## TIM AUDIT & PESERTA AUDITI

|           |                         |                                 |
|-----------|-------------------------|---------------------------------|
| <b>SA</b> | Syahril Arfian Almazril | Lead Auditor<br>Ketua Tim Audit |
| <b>RC</b> | Rina Clarissa           | Head of Human Capital           |
| <b>LA</b> | Lorent Aprilia          | Human Capital Staff             |
| <b>GR</b> | Tim IT GRC              | IT GRC Lead                     |
| <b>EN</b> | Head of Engineering     | Engineering                     |
| <b>OP</b> | Head of Operations      | Operations                      |

## METODOLOGI & FORMAT TEMUAN CPLOR

- C Compliance** - konteks kepatuhan yang sudah dipenuhi auditi.
- P Problem** - kesenjangan / ketidaksesuaian yang teridentifikasi.
- L Location** - area spesifik dalam lingkup ISMS.
- O Objective Evidence** - audit trail, dokumen, wawancara, observasi.
- R Reference** - klausul ISO 27001:2022, kebijakan, atau regulasi.

|                          |                            |                            |
|--------------------------|----------------------------|----------------------------|
| 10<br>Data karyawan baru | 4<br>Kuartal access review | 5<br>Sampel Change Request |
|--------------------------|----------------------------|----------------------------|

## JADWAL AKTIVITAS - 6 S.D. 24 JANUARI 2026

- 1** 6 - 10 Jan 2026 · **Peninjauan Dokumen**  
Review kebijakan, risk register, access review report, sampel change request & dokumen onboarding.
- 2** 13 - 17 Jan 2026 · **Wawancara & Observasi**  
Wawancara pemilik proses; observasi kontrol akses fisik & audit trail sistem.
- 3** 20 - 24 Jan 2026 · **Penyusunan & Pelaporan**  
Penyusunan laporan, closing meeting & distribusi kepada Top Management.

# Empat Major Non-Conformity Teridentifikasi

Total Temuan4

Major NC4

Minor NC / OFI0 / 0

| KODE | AREA                 | TEMUAN                                                                           | KLASIFIKASI | REFERENSI UTAMA                    |
|------|----------------------|----------------------------------------------------------------------------------|-------------|------------------------------------|
| F-01 | Human Capital        | SKCK belum diserahkan oleh 5 dari 10 karyawan baru (50%) dalam 1 tahun terakhir. | Major NC    | Annex A.6.1 · PNP/HC/012/2023      |
| F-02 | IT GRC - Risk Mgmt   | Risk Assessment belum diperbarui pasca-relokasi kantor (selisih > 6 bulan).      | Major NC    | Clause 8.2 · Clause 6.1.2          |
| F-03 | IT GRC - Access Ctrl | Access review Q3 2025 tidak lengkap & Q4 2025 belum dilaksanakan.                | Major NC    | Annex A.5.15 / A.5.18 · PNP/IT/002 |
| F-04 | Engineering          | CR 1010 (firewall rule) diimplementasi di production tanpa persetujuan lengkap.  | Major NC    | Annex A.8.32 / A.8.20 · PNP/IT/004 |

# Background Screening - Ketidaklengkapan SKCK

Major NC

Human Capital

Annex A.6.1

PNP/HC/012/2023 v1.2

Identifikasi: 14 Januari 2026

## P PROBLEM

5 dari 10 karyawan baru (50%) tidak menyerahkan SKCK; tindak lanjut pengumpulan belum dilaksanakan Tim HC.

## O BUKTI OBJEKTIF

| Karyawan              | Jabatan               | Bergabung   | SKCK  |
|-----------------------|-----------------------|-------------|-------|
| Andi Pratama Wijaya   | HR Staff              | 17 Okt 2025 | Tidak |
| Dewi Maharani Sasmita | IT GRC                | 16 Okt 2025 | Tidak |
| Eko Budi Prasetyo     | iOS Engineer          | 1 Nov 2025  | Tidak |
| Maya Sari Purnamasari | Finance Staff         | 18 Des 2025 | Tidak |
| Rendy Kurniawan Putra | Onboarding Specialist | 1 Jan 2026  | Tidak |

## C KONTEKS KEPATUHAN

Kebijakan PNP/HC/012/2023 v1.2 mewajibkan SKCK valid (≤3 bulan). 5 karyawan lain telah memenuhi persyaratan.

### ANALISIS RISIKO

Potensi **insider threat** pada posisi IT GRC, iOS Engineer & Finance Staff. Berisiko menjadi Major NC pada Surveillance Audit Juni 2026 yang berdampak ke sertifikasi.

### AKAR PENYEBAB (RCA)

Tidak ada **blocking item / gating otomatis** pada onboarding; turnover PIC onboarding (Sep 2025) tanpa handover & backup PIC.

### RENCANA TINDAKAN KOREKTIF (CAP)

- Recall & kumpulkan SKCK 5 karyawan terdampak (SLA ≤14 hari kerja).
- Onboarding checklist digital HRIS - SKCK sebagai **blocking item** sebelum status active.
- Tetapkan backup PIC untuk setiap proses kritikal HC.
- Revisi kebijakan: tambah klausul SLA & mekanisme eskalasi.

| DUE DATE     | TARGET   | VERIFIKASI | STATUS |
|--------------|----------|------------|--------|
| 30 / 60 hari | Feb 2026 | Mar 2026   | Open   |



# Risk Assessment Belum Diperbarui Pasca-Relokasi

Major NC

IT GRC - Risk Management

Clause 8.2

Clause 6.1.2

Klausul mandatori

**P** PROBLEM

Risk Assessment belum diperbarui untuk mencerminkan perubahan signifikan (relokasi kantor) - **selisih > 6 bulan** per 6 Jan 2026.

**O** BUKTI OBJEKTIF - KRONOLOGI

| Waktu        | Peristiwa                                                           |
|--------------|---------------------------------------------------------------------|
| April 2025   | RA terakhir - seluruh risiko acuan Gedung 123, Bojongsoang, Bandung |
| Juni 2025    | Operasional pindah ke Jakarta                                       |
| Juli 2025    | Infrastruktur IT pindah ke Jakarta                                  |
| Agustus 2025 | Operasional Bandung dihentikan                                      |
| 6 Jan 2026   | <b>Tidak ada RA pemutakhiran / delta assessment</b>                 |

**C** KONTEKS KEPATUHAN

RA April 2025 terdokumentasi, dengan kriteria penilaian & **risk owner** teridentifikasi.

**ANALISIS RISIKO**

Ancaman baru Jakarta (kepadatan urban, kejahatan siber, banjir, vendor baru) **tidak tercakup**. Pelanggaran Clause 8.2 (mandatori) umumnya menjadi **show-stopper** pada surveillance audit.

**AKAR PENYEBAB (RCA)**

Metodologi RA hanya berbasis **kalender (annual)** ; tidak ada trigger event-driven untuk significant change.

**RENCANA TINDAKAN KOREKTIF (CAP)**

- RA refresh khusus dampak relokasi (lokasi, vendor lokal, akses gedung, BCP), disahkan **risk owner**.
- Selaraskan hasil RA dengan **SoA, Risk Treatment Plan & BCP** ; sahkan via MRM.
- Update metodologi RA - tambah **trigger event-driven** (relokasi, akuisisi, insiden major).

| DUE DATE     | TARGET   | VERIFIKASI | STATUS      |
|--------------|----------|------------|-------------|
| 30 / 60 hari | Mar 2026 | Apr 2026   | <b>Open</b> |

# Access Review Q3 & Q4 2025 Tidak Terlaksana Penuh

Major NC

IT GRC - Access Control

Annex A.5.15

A.5.18

PNP/IT/002/2023 v1.1

**P** PROBLEM

Access review Q3 2025 tidak lengkap & Q4 2025 belum dilaksanakan - **2 kuartal berturut-turut menyimpang** dari kebijakan.

**O** BUKTI OBJEKTIF - ACCESS REVIEW 2025

| Kuartal | Cakupan                                  | Status             |
|---------|------------------------------------------|--------------------|
| Q1 2025 | GCP, Critical Apps, GitHub               | Lengkap            |
| Q2 2025 | GCP, Critical Apps, GitHub               | Lengkap            |
| Q3 2025 | Hanya GCP (tanpa Critical Apps & GitHub) | Tidak lengkap      |
| Q4 2025 | -                                        | Belum dilaksanakan |

**C** KONTEKS KEPATUHAN

Kebijakan **PNP/IT/002/2023 v1.1** mewajibkan access review tiap kuartal atas GCP, Critical Apps & GitHub.

**ANALISIS RISIKO**

Akses **stale & orphan account** , privilege creep, dan insider threat terhadap **GitHub** (source code produksi); kegagalan mekanisme eskalasi tata kelola.

**AKAR PENYEBAB (RCA)**

Kapasitas Tim IT GRC **hanya 1 anggota sejak Q3 2025** tanpa mitigasi tereskalasi; tidak ada otomasi access review.

**RENCANA TINDAKAN KOREKTIF (CAP)**

- Selesaikan access review Q4 2025 (prioritas **GitHub**).
- Retroactive review gap Q3 (Critical Apps & GitHub).
- Penambahan kapasitas Tim IT GRC (rekrutmen / cross-functional).
- Otomasi report IAM (quick win) → **IGA tool** jangka panjang.

| DUE DATE     | TARGET   | VERIFIKASI | STATUS |
|--------------|----------|------------|--------|
| 21 / 60 hari | Feb 2026 | Apr 2026   | Open   |

# Change Request CR 1010 Tanpa Persetujuan Lengkap

Major NC

Engineering

Annex A.8.32

A.8.20

PNP/IT/004/2023 v1.1

## P PROBLEM

CR 1010 (penambahan firewall rule aset 'fw-xyz-01' ) telah diimplementasi di production **tanpa persetujuan lengkap** Infrastructure Lead & Business Operations Lead.

## O BUKTI OBJEKTIF

Konfigurasi production firewall menunjukkan rule aktif yang memblokir traffic sesuai cakupan CR 1010. Dokumentasi CR 1010: **status approval belum lengkap** - mismatch terverifikasi antara implementasi & governance.

## C KONTEKS KEPATUHAN

Dari 5 sampel CR, **4 sudah benar** (CR 1011, CR 1000, CR 997, CR 956) sesuai kebijakan PNP/IT/004/2023 v1.1.

## ANALISIS RISIKO

Ketersediaan layanan (rule tanpa validasi Business Ops dapat memblokir traffic sah), integritas konfigurasi jaringan, audit trail, & **bypass control sistemik** - kemungkinan ada CR lain serupa.

## AKAR PENYEBAB (RCA)

Tidak ada **technical enforcement (workflow gating)** ; approval bergantung kepatuhan manual sehingga rentan bypass akibat tekanan operasional.

## RENCANA TINDAKAN KOREKTIF (CAP)

1. Retroactive approval CR 1010 oleh Infrastructure & Business Ops Lead - jika ditolak, **rollback** rule.
2. Extended sampling min. **20 CR tambahan** (12 bulan terakhir).
3. Implementasi **workflow gating** + integrasi IaC / CI-CD policy-as-code.
4. Kebijakan: 'No production change without complete approval AND peer review.'

| DUE DATE          | TARGET   | VERIFIKASI | STATUS |
|-------------------|----------|------------|--------|
| 14 / 45 / 90 hari | Feb 2026 | Apr 2026   | Open   |



# Pola Sistemik & Jalur Penyelesaian Sebelum Juni 2026

## — TIGA POLA AKAR PENYEBAB

- 1

**Keterbatasan Sumber Daya Manusia**  
Tim IT GRC hanya 1 anggota sejak Q3 2025; turnover PIC onboarding HC pada September 2025.
- 2

**Lemahnya Follow-up & Eskalasi**  
Tidak ada checklist gating onboarding; tidak ada eskalasi formal atas keterbatasan kapasitas access review.
- 3

**Lemahnya Enforcement Kontrol di Sistem**  
Change Request dapat dieksekusi tanpa approval lengkap; tidak ada pemicu RA berbasis significant change.

 **Penilaian Kesiapan Surveillance**

Tanpa tindakan korektif segera, perusahaan **berpotensi menerima Major NC** pada Surveillance Audit Juni 2026 - namun keempat temuan dinilai **dapat diselesaikan tepat waktu** bila CAP dijalankan dengan prioritas.

Audit berbasis **sampling** - auditi disarankan melakukan self-assessment populasi penuh, khususnya F-01 & F-04.

## — TARGET TIMELINE PENYELESAIAN (CAP)

| KODE | TINDAKAN KOREKTIF UTAMA                                | TARGET       | VERIFIKASI |
|------|--------------------------------------------------------|--------------|------------|
| F-01 | Recall SKCK 5 karyawan + checklist gating digital HRIS | Feb 2026     | Mar 2026   |
| F-02 | RA refresh pasca-relokasi + sinkronisasi SoA & BCP     | Mar 2026     | Apr 2026   |
| F-03 | Access review Q4 + retroaktif Q3 + kapasitas tim       | Feb 2026     | Apr 2026   |
| F-04 | Approval CR 1010 + extended sampling + workflow gating | Feb-Apr 2026 | Apr 2026   |

## — TATA KELOLA TINDAK LANJUT

|                                                                                           |                                                                                                  |                                                                               |
|-------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| <b>CAP ≤ 14 Hari Kerja</b><br>PIC, root cause & target ditetapkan sejak laporan diterima. | <b>Follow-up - Apr 2026</b><br>Verifikasi efektivitas tindakan korektif sebelum audit eksternal. | <b>MRM - Clause 9.3</b><br>Pembahasan temuan dalam Management Review Meeting. |
|-------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------|

## Audit yang Objektif, Tindak Lanjut yang Terukur

- ✓ **4 Major Non-Conformity** telah dikomunikasikan & dikonfirmasi auditi pada closing meeting 24 Januari 2026.
- 🕒 Seluruh CAP ditargetkan selesai & terverifikasi sebelum **Surveillance Audit Juni 2026**.
- 👥 Audit independen & berbasis bukti - kami mengharapkan **kooperasi seluruh auditi**.



**Syahril Arfian Almazril**

Ketua Tim Audit Internal · Lead Auditor

## Terima Kasih

Atas waktu, keterbukaan, dan kerja sama dalam pelaksanaan audit internal SMKI ini.

|             |                              |
|-------------|------------------------------|
| No. Laporan | LAI/ISMS/001/I/2026          |
| Periode     | 6 - 24 Januari 2026          |
| Temuan      | 4 Major NC · 0 Minor · 0 OFI |
| Target      | Surveillance 1 - Juni 2026   |